

ISO/IEC 27001:2022: Certification Is Now Mandatory, Not Optional

The transition deadline has passed. Here's what that actually means for a 2013-certified organisation.

A Digital Asset Defenders Deep-Dive Guide | Updated August 2026

Introduction

ISO/IEC 27001:2022 replaced the 2013 edition of the world's leading information security management system (ISMS) standard on 25 October 2022. The International Accreditation Forum (IAF) set a three-year transition window for existing certificate holders — and that window closed on 31 October 2025. Any organisation still holding an ISO/IEC 27001:2013 certificate today is no longer certified to a recognised standard: certificates issued or reissued against the 2013 edition during the transition period carried 31 October 2025 as their expiry date, regardless of the usual three-year validity cycle.

This is not a minor administrative update. This guide covers what actually changed in the standard, what happens if your organisation missed the deadline, and how to approach certification or recertification against the only version that now exists.

Transition Timeline

Date	Milestone
25 October 2022	ISO/IEC 27001:2022 published; three-year transition window begins
30 April 2024	Certification bodies stop issuing new initial certifications against the 2013 edition
31 July 2025	All transition audits (recertification and surveillance) were expected to be completed
31 October 2025	Transition window closes; all remaining 2013 certificates expire or are withdrawn
1 January 2026	Global Accreditation Cooperation Incorporated (GACI) begins operating, taking over international accreditation functions previously split between IAF and ILAC

If your certificate lapsed

An expired ISO/IEC 27001:2013 certificate is not eligible for a lighter “transition audit” any longer. Certification bodies now treat a lapsed organisation as a new client, requiring a full Stage 1 and Stage 2 audit against the 2022 edition — a materially longer and more expensive process than the transition path that was available before the deadline.

What Actually Changed in the Standard

Annex A restructured and consolidated

The most visible change is in Annex A, which governs the specific security controls an ISMS can select from. The previous 114 controls spread across 14 domains have been consolidated into 93 controls organised under four themes:

Theme	Controls
Organisational	37
People	8
Physical	14
Technological	34

Eleven new controls

Eleven controls are entirely new, reflecting how the threat landscape and technology stack have shifted since 2013 — particularly around cloud, threat intelligence, and secure development:

- 5.7 — Threat intelligence
- 5.23 — Information security for use of cloud services
- 5.30 — ICT readiness for business continuity
- 7.4 — Physical security monitoring
- 8.9 — Configuration management
- 8.10 — Information deletion
- 8.11 — Data masking
- 8.12 — Data leakage prevention
- 8.16 — Monitoring activities
- 8.23 — Web filtering
- 8.28 — Secure coding

Supply chain controls (5.19–5.22)

These four controls cover the full supplier relationship lifecycle. Control 5.21, addressing ICT supply chain security specifically, is the one auditors probe hardest — and evidence for it increasingly requires organisations to produce a Software Bill of Materials (SBOM) for any in-house software, mirroring a requirement that has also become mandatory under PCI DSS v4.0.1.

ISMS clause updates

Beyond Annex A, the management system clauses themselves picked up new or revised requirements: Clause 4.4 (understanding the interaction between ISMS processes), Clause 6.3 (planning changes to the ISMS), and Clause 9.1 (evaluating ISMS performance) all carry meaningfully expanded expectations compared with 2013.

Migration Strategy

The cleanest way to approach migration is as a structured remap rather than a rebuild. Eighty-two of the retained controls map directly from the 2013 structure with only cosmetic changes. The eleven new controls need fresh, individual risk analysis — exclusion is permitted where a control genuinely doesn't apply, but that exclusion has to be defensible and documented in the Statement of Applicability, not simply asserted. Your risk treatment plan needs to be restructured around the new four-theme layout without losing the historical risk register that documents why past decisions were made.

- 1 Gap-assess your current ISMS against the 2022 Annex A structure and the updated management clauses.
- 2 Individually risk-assess each of the eleven new controls; document any exclusions in the SoA with clear justification.
- 3 Update the risk treatment plan and control implementation evidence to the new theme structure.
- 4 Run an internal audit against the 2022 requirements before your external audit.
- 5 Engage your certification body early — best practice is starting 12–18 months ahead of any renewal or first-time certification, given constrained auditor availability post-deadline.

Why This Matters for Kenyan and East African Organisations

ISO 27001 certification is frequently a prerequisite for enterprise and government procurement, and for correspondent banking and partnership relationships with international financial institutions. A lapsed certificate doesn't just create an internal governance gap — it can immediately disqualify an organisation from tenders and contract renewals that specify current certification. For organisations pursuing DPA, PCI DSS, or CBK cybersecurity compliance in parallel, the 2022 edition's new cloud security, threat intelligence, and secure coding controls also map cleanly onto obligations those other frameworks already require, making a well-executed ISO 27001:2022 implementation a strong backbone for the rest of a compliance programme rather than a parallel exercise.

How Digital Asset Defenders Can Help

- ISO/IEC 27001:2022 gap analysis for both first-time certification and lapsed-certificate recovery
- Annex A control mapping and Statement of Applicability development
- Implementation support for the eleven new controls, including SBOM generation for control 5.21
- ISMS documentation: policies, risk register, risk treatment plan
- Internal audits ahead of your certification body's external audit
- Certification body liaison and audit support

With the transition deadline behind us, ISO/IEC 27001:2022 is simply what “ISO 27001 certified” means now. Whether you're recovering from a lapsed 2013 certificate or pursuing certification for the first time, the earlier you start the fresh risk analysis the new controls require, the less disruptive the process will be. Contact Digital Asset Defenders to scope your gap assessment.

Sources & Further Reading

- ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements
- SGS, “Last Chance to Transition to ISO/IEC 27001:2022 and Next Steps If You Miss the Deadline”
- A-LIGN, “ISO 27001 Transition: What Now?”
- BrightDefense, “ISO 27001:2022 Deadline Puts Legacy Certificates At Risk”, June 2026
- BALTUM, “ISO 27001:2022 Transition — What You Need to Know Before the Deadline”
- databrackets, “The ISO 27001:2022 Update”